

SESIÓN EVALUACIÓN DEL MODELO DE RESPONSABILIDAD COMPARTIDA

CONTENIDOS:

- Modelo de responsabilidad compartida:
 - Definición: qué es un modelo de responsabilidad compartida.
 - Responsabilidades del proveedor.
 - Responsabilidades del cliente.
- Escenarios según modelo de servicio:
 - Diferencias en el modelo de responsabilidad compartida en IAAS, PAAS y SAAS.
 - Ejemplos de incidentes por falta de claridad en la aplicación del modelo.
- Evaluación de riesgos:
 - Impacto de no comprender o aplicar correctamente el modelo de responsabilidad.
 - Medidas de mitigación.

MODELO DE RESPONSABILIDAD COMPARTIDA

En la nube, el modelo de responsabilidad compartida distribuye las tareas de seguridad entre el proveedor de servicios en la nube (CSP) y el cliente. A diferencia de la infraestructura tradicional, en la que una organización posee control total sobre sus sistemas, en la nube, algunos aspectos de la seguridad se delegan al proveedor, mientras que otros recaen en el cliente. El CSP asegura la infraestructura global y los aspectos físicos, mientras que el cliente mantiene la seguridad y configuración de su propio entorno. Este enfoque reduce el riesgo, optimiza la gestión de recursos y permite a los clientes centrarse en la protección de sus datos y aplicaciones.

Responsabilidades del Proveedor

Los proveedores de servicios en la nube asumen tareas relacionadas con la infraestructura general y los sistemas físicos y operativos. Las principales áreas de responsabilidad del proveedor incluyen:

- Seguridad Física: Protección de los centros de datos mediante medidas de seguridad como vigilancia, acceso controlado y monitoreo constante.

- **Infraestructura de Red y Hardware:** Asegurar la red, el hardware y el software que soportan los servicios en la nube, incluyendo la encriptación de las comunicaciones.
- **Seguridad de Datos en Tránsito:** Uso de protocolos de cifrado y seguridad para los datos que viajan entre el cliente y la infraestructura de la nube.
- **Cumplimiento de Regulaciones:** Certificación de que la infraestructura cumple con estándares de seguridad y regulaciones globales, como ISO 27001 y SOC 2.
- **Redundancia y Recuperación:** Implementación de backups y estrategias de recuperación ante desastres para la disponibilidad continua de los servicios.

Responsabilidades del Cliente

El cliente de servicios en la nube es responsable de administrar la seguridad de los datos y aplicaciones que aloja en la nube. Las tareas de seguridad que debe asumir incluyen:

- **Control de Acceso:** Configuración de políticas de acceso y autenticación para proteger aplicaciones y datos almacenados en la nube.
- **Cifrado de Datos en Reposo:** Aplicar cifrado a los datos almacenados en la nube para evitar accesos no autorizados.
- **Configuración de Seguridad:** Asegurar que las configuraciones de aplicaciones y servicios en la nube estén protegidas y actualizadas.
- **Supervisión y Auditoría:** Monitorear el uso de recursos y realizar auditorías de seguridad para detectar accesos no autorizados.
- **Respaldo y Recuperación:** Mantener copias de seguridad y establecer planes de recuperación de datos en caso de fallos o ataques.

ESCENARIOS SEGÚN MODELO DE SERVICIO

Diferencias en el Modelo de Responsabilidad Compartida en IAAS, PAAS y SAAS

Dependiendo del tipo de servicio, las responsabilidades específicas varían entre proveedor y cliente. A continuación, se muestra una tabla con las diferencias clave en cada modelo.

Modelo de Servicio	Responsabilidad del Proveedor	Responsabilidad del Cliente
IAAS (Infraestructura como Servicio)	Infraestructura física, red, almacenamiento y virtualización	Sistemas operativos, aplicaciones, datos y acceso a la red
PAAS (Plataforma como Servicio)	Infraestructura, sistema operativo, y administración de bases de datos	Datos, configuración de aplicaciones y administración de usuarios
SAAS (Software como Servicio)	Aplicación completa y su infraestructura subyacente	Configuración de accesos, gestión de usuarios y protección de datos sensibles

Ejemplos de Incidentes por Falta de Claridad en la Aplicación del Modelo

1. IAAS (Infraestructura como Servicio):

Un cliente no implementa autenticación multifactor (MFA) para los usuarios con permisos administrativos en sus servidores virtuales en la nube. Debido a esta omisión, los usuarios malintencionados pueden acceder fácilmente a los servidores si obtienen las credenciales. Al confiar únicamente en contraseñas y no implementar MFA, el cliente deja una



vulnerabilidad abierta que aumenta el riesgo de accesos no autorizados y compromete la seguridad de sus recursos críticos en la nube.

2. PAAS (Plataforma como Servicio):

Un cliente no configura adecuadamente los controles de acceso a su base de datos de clientes, alojada en la nube. Como resultado, usuarios externos o no autorizados pueden acceder a esta base de datos, exponiendo datos personales o confidenciales. Esta situación podría haberse evitado si el cliente hubiera establecido permisos específicos y control de accesos, asegurándose de que solo usuarios internos y autorizados puedan visualizar o modificar los datos de clientes. Este incidente subraya la importancia de que el cliente entienda su rol en la configuración y seguridad de los servicios en el modelo PAAS.

3. SAAS (Software como Servicio):

En una aplicación de gestión documental utilizada por una organización, el cliente no ajusta los permisos predeterminados proporcionados por el servicio. Esto permite que empleados de diferentes departamentos tengan acceso innecesario a documentos confidenciales. Al no realizar una configuración adecuada de los permisos de acceso, el cliente facilita la exposición de datos sensibles, generando riesgos de privacidad y posibles conflictos internos. Este tipo de incidente resalta la necesidad de que el cliente comprenda y gestione las configuraciones de acceso en el modelo SAAS para proteger la integridad y confidencialidad de los datos.

EVALUACIÓN DE RIESGOS

Impacto de No Comprender o Aplicar Correctamente el Modelo de Responsabilidad Compartida

La falta de una comprensión clara del modelo de responsabilidad compartida puede llevar a brechas de seguridad, pérdida de datos y otros incidentes de seguridad graves. Si el cliente no comprende su rol en la protección de los datos, es posible que asuma incorrectamente que el proveedor se encargará de todos los aspectos de seguridad, lo cual puede dejar vulnerabilidades abiertas. Por ejemplo:

- **Robo de Información:** Si un cliente no aplica políticas de acceso seguras, usuarios no autorizados podrían acceder a información confidencial.

- Pérdida de Datos: La falta de respaldo de los datos críticos puede provocar su pérdida en caso de fallos o ataques.
- Violación de la Privacidad de Usuarios: Un cliente que no asegure adecuadamente los datos personales puede enfrentar sanciones por incumplir normativas de privacidad como el GDPR.

Medidas de Mitigación

Para gestionar los riesgos y asegurar el cumplimiento adecuado del modelo de responsabilidad compartida, se deben tomar medidas como:

- Capacitación y Concientización: Entrenar a los empleados y administradores para que comprendan las responsabilidades en la nube y el alcance del modelo compartido.
- Establecimiento de Políticas de Seguridad: Crear políticas internas de seguridad que detallen cómo gestionar la seguridad de los recursos en la nube y las tareas de cada equipo.
- Auditoría y Supervisión Continua: Implementar auditorías regulares para monitorear el cumplimiento de las políticas de seguridad y la gestión de accesos.
- Configuración de Herramientas de Monitoreo y Seguridad: Utilizar herramientas de detección de amenazas y configuraciones automatizadas para asegurar la aplicación de controles de seguridad.
- Acuerdos de Nivel de Servicio (SLA): Revisar los acuerdos de nivel de servicio con los proveedores para asegurar que cumplen con las necesidades de la organización y garantizan su seguridad.

El modelo de responsabilidad compartida es fundamental para la seguridad en la nube, ya que permite dividir claramente las tareas de protección entre el proveedor y el cliente. Comprender y aplicar correctamente este modelo no solo evita vulnerabilidades de seguridad, sino que también fortalece la resiliencia de los sistemas en la nube. Las organizaciones que integran estos principios de seguridad y gestionan adecuadamente sus responsabilidades garantizan que los datos y aplicaciones en la nube se mantengan seguros, confiables y en cumplimiento con las normativas vigentes.